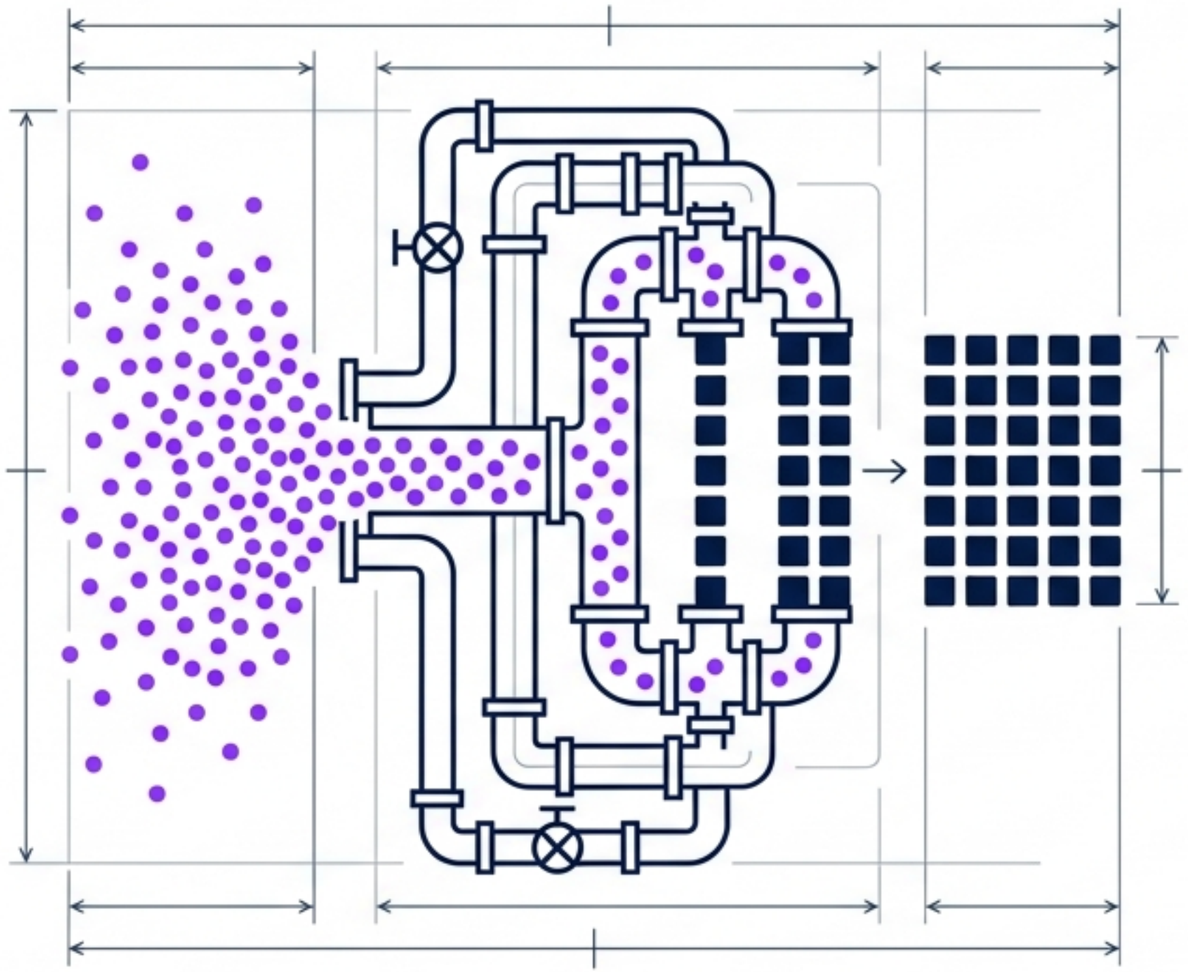


Architecting the EU AI Act Guardrail & Compliance Sandbox

A modular, evidence-driven platform for deterministic AI governance.

Gemini Notebook

The Constraints of Law

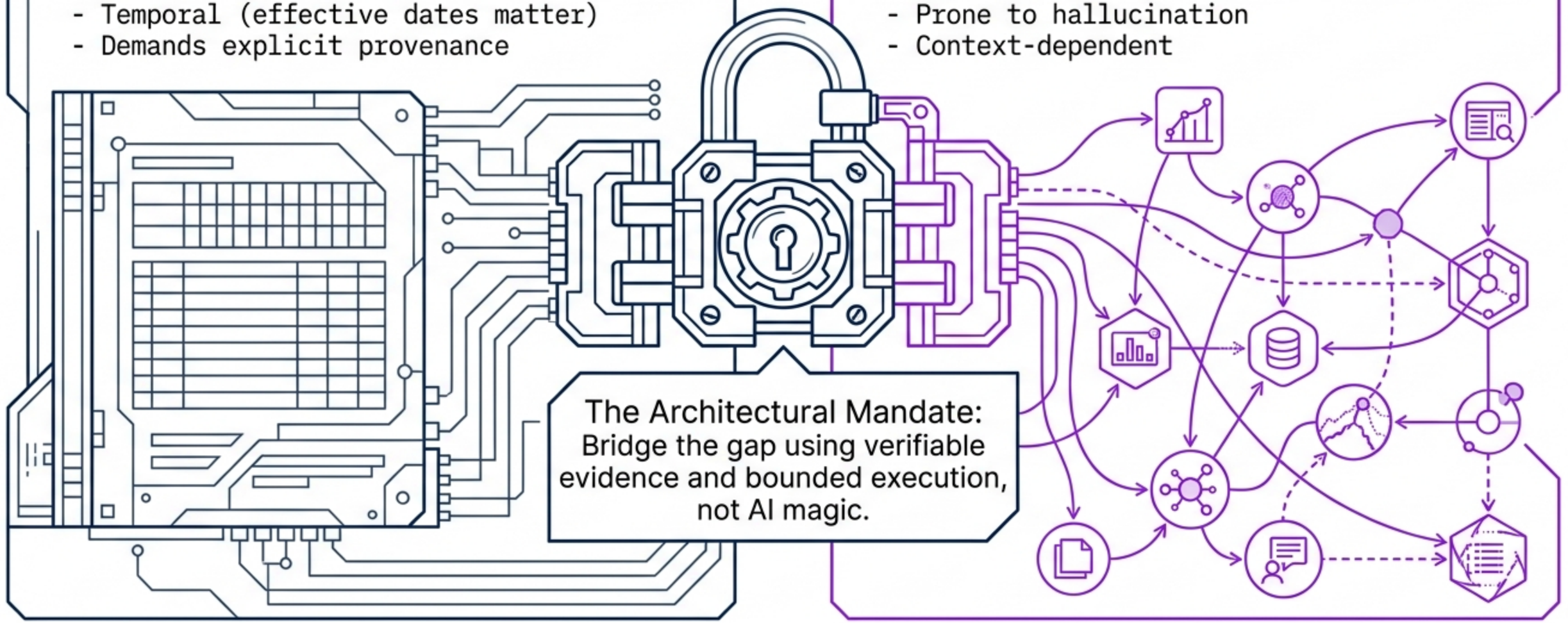
EU AI Act & GDPR Requirements

- Deterministic
- Versioned and immutable
- Temporal (effective dates matter)
- Demands explicit provenance

The Reality of GenAI

LLMs & Agentic Systems

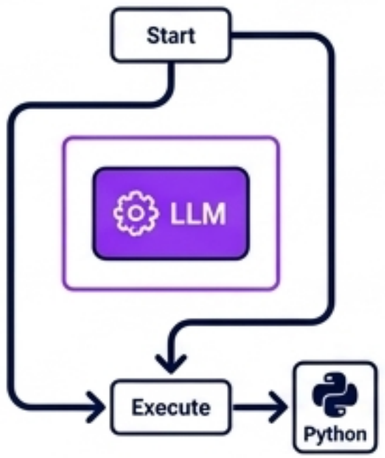
- Probabilistic and non-deterministic
- Opaque reasoning
- Prone to hallucination
- Context-dependent



The Architectural Mandate:
Bridge the gap using verifiable evidence and bounded execution, not AI magic.

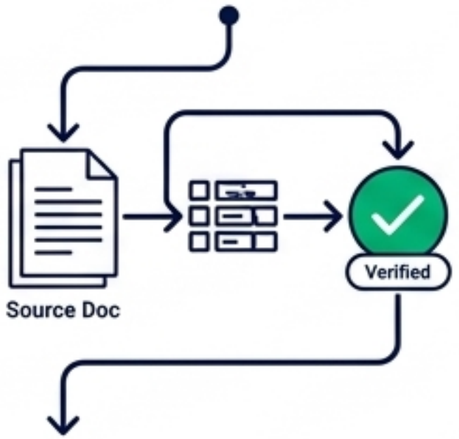
Gemini Notebook

Core Design Principles



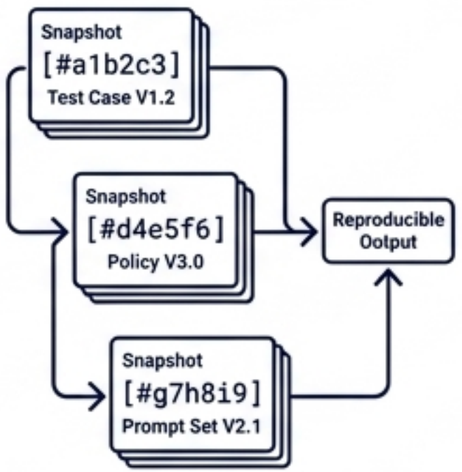
Rules Over Unrestricted LLM Judgment

Explicit regulatory conditions execute in Python. AI is reserved strictly for unstructured context extraction.



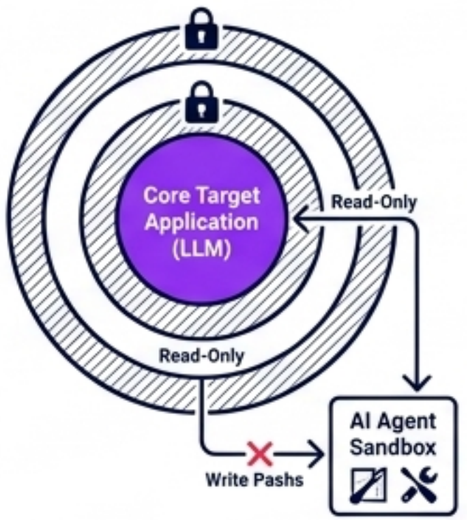
Evidence Before Conclusions

Every material finding must reference an applicable regulatory source or verifiable execution log.



Reproducibility by Design

Versioned test cases, regulatory sources, prompts, and assessment policies.

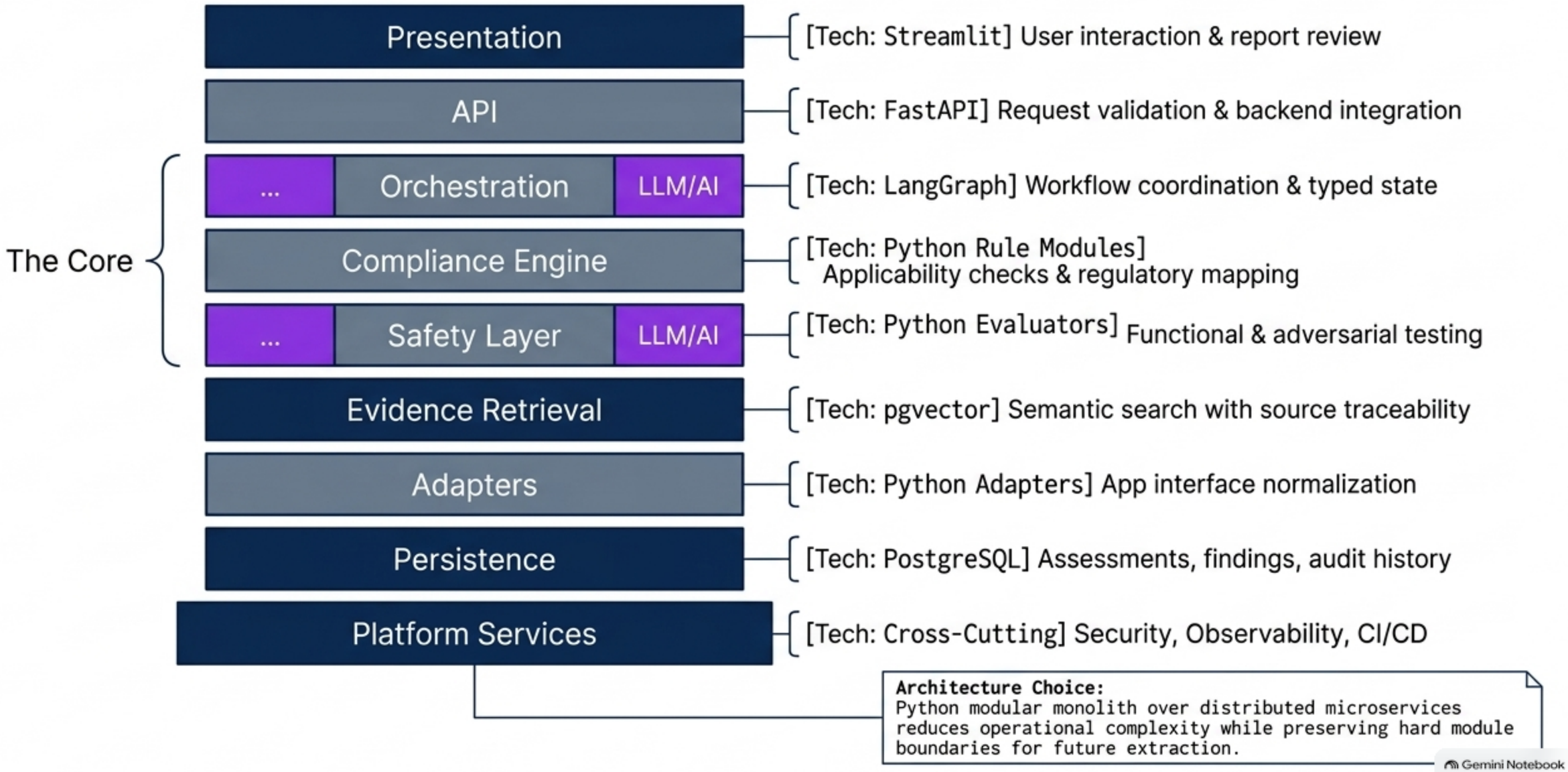


Least Privilege Execution

Target applications run in isolated sandboxes. AI agents have restricted toolsets and no autonomous write access.

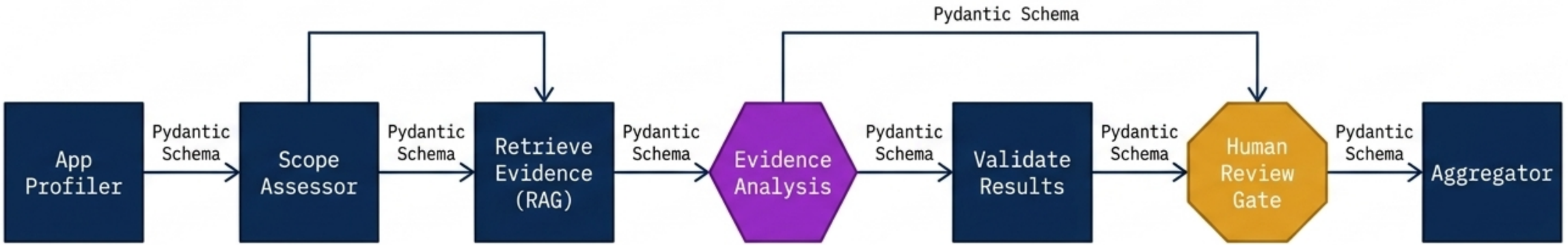
Gemini Notebook

High-Level System Topology



Gemini Notebook

Agent & Workflow Architecture



Constraint Callout: Workflow over autonomy.

There are NO autonomous agents running free. Conditional routing is handled by deterministic Python policies, never by the LLM.

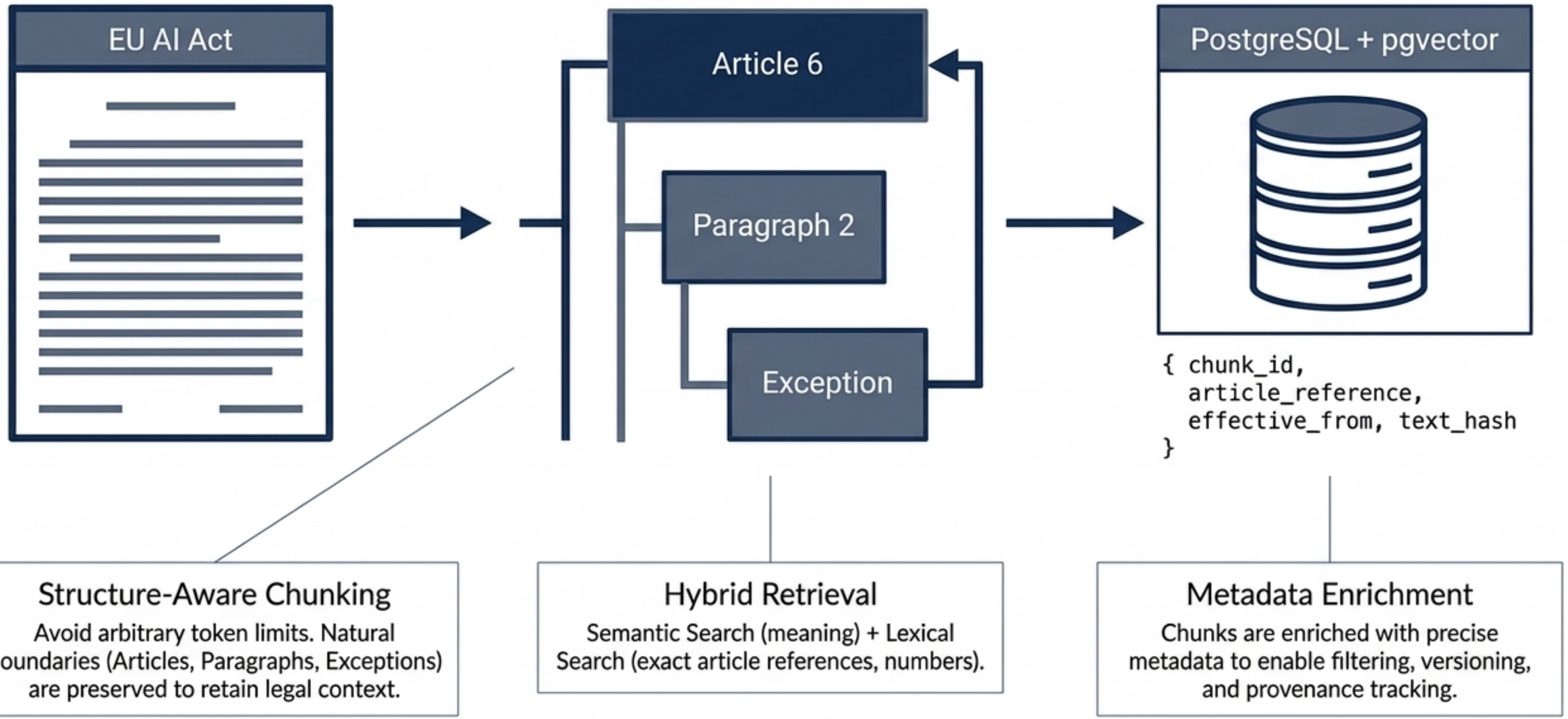
Gemini Notebook

The Tri-Modal Compliance Engine

Deterministic Rules	Evidence-Assisted Analysis	Behavioral Evaluation
Execution Python logic.	**Execution** LLM + Pydantic Validation.	**Execution** Isolated Runner / Red-Teaming.
LLM Role None.	**LLM Role** Extraction & Summarization.	**LLM Role** Attack Generation & Output Judge.
Example Use Case Explicit legal conditions (e.g., checking if the app falls under an Annex III high-risk category).	**Example Use Case** Interpreting unstructured system descriptions against retrieved Article 50 transparency obligations.	**Example Use Case** Testing resistance to prompt-injection or sensitive-data exfiltration.
Limits of Evidence Absolute certainty based on provided inputs.	**Limits of Evidence** Requires human review for ambiguous legal classifications.	**Limits of Evidence** Proves observed technical risk, but does not independently establish legal compliance.

Gemini Notebook

Data & RAG Architecture: Structure-Aware Ingestion



Structure-Aware Chunking

Avoid arbitrary token limits. Natural boundaries (Articles, Paragraphs, Exceptions) are preserved to retain legal context.

Hybrid Retrieval

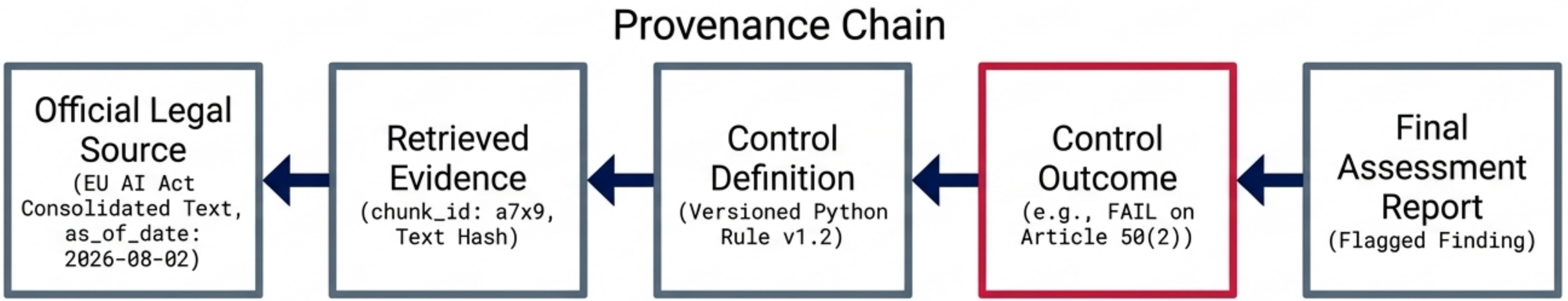
Semantic Search (meaning) + Lexical Search (exact article references, numbers).

Metadata Enrichment

Chunks are enriched with precise metadata to enable filtering, versioning, and provenance tracking.

Gemini Notebook

The Provenance Trace

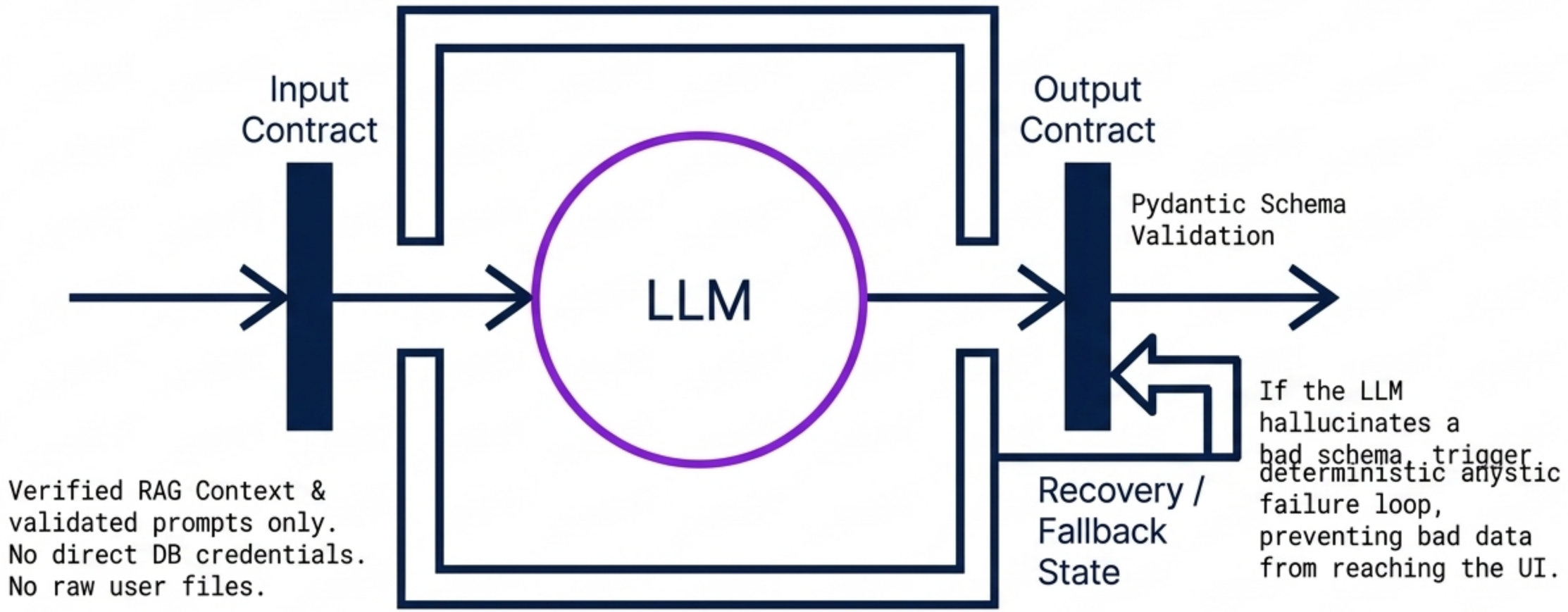


Similarity scores are not legal proof. Every material finding is deterministically linked to a hashed, versioned, official regulatory source

Gemini Notebook

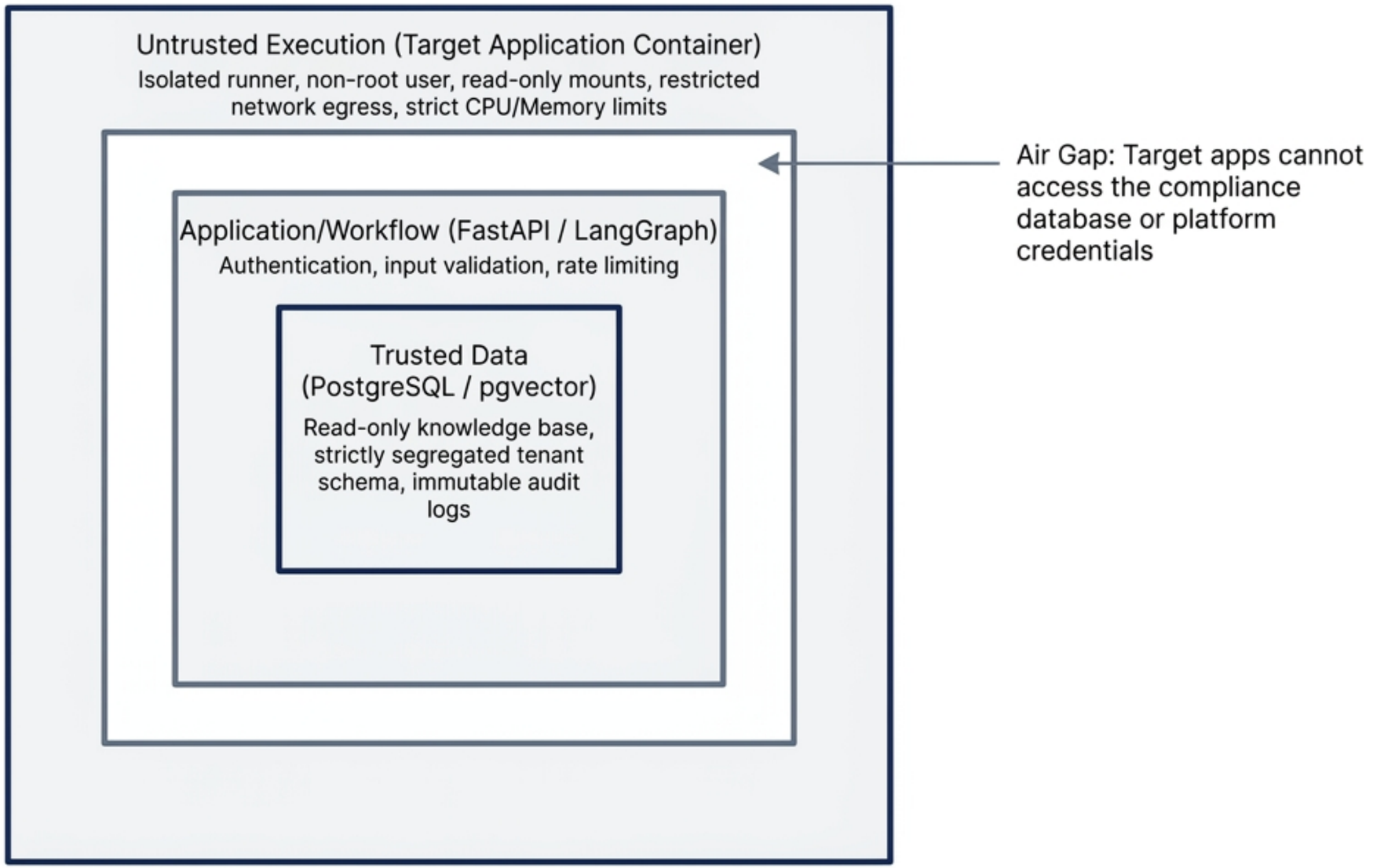
Bounding the LLM: Input/Output Contracts

Treat LLMs as untrusted, fallible functions wrapped in traditional software engineering rigor.



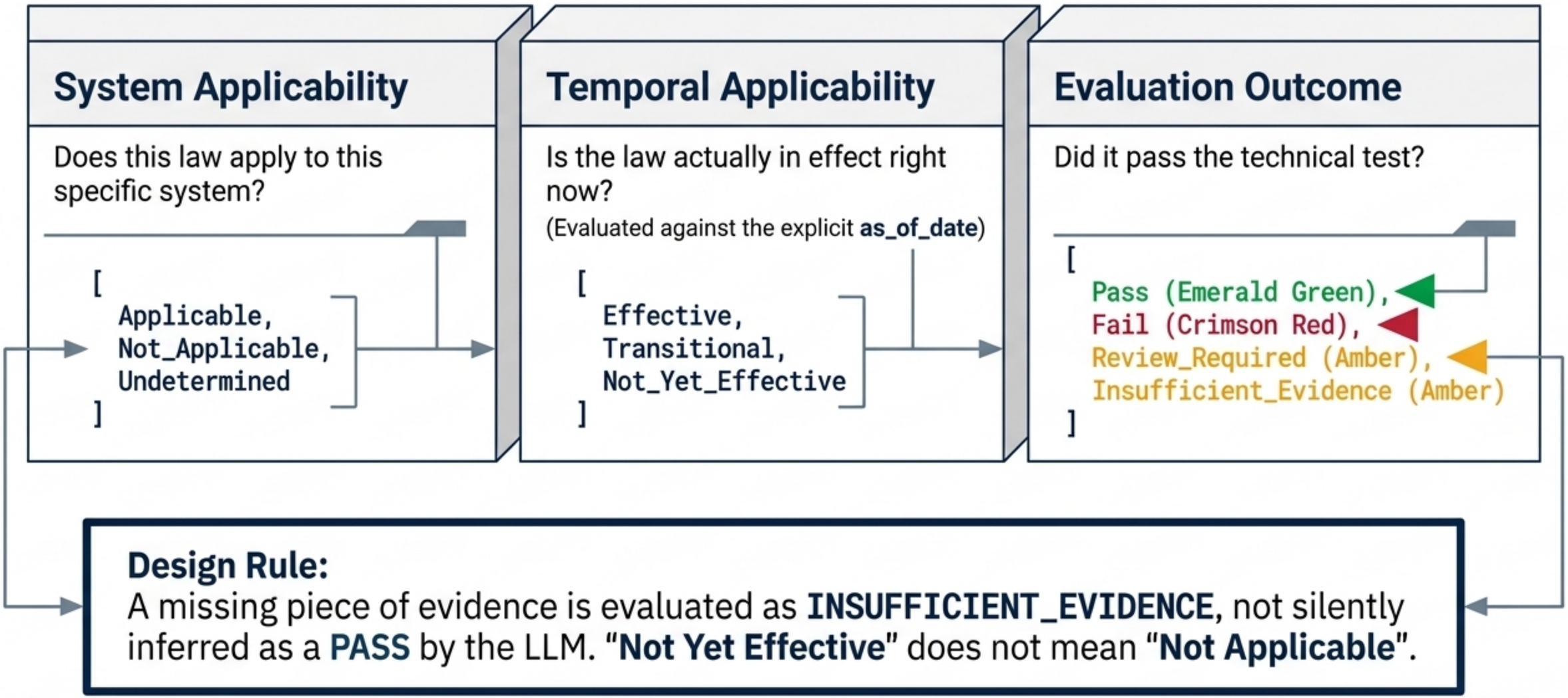
Gemini Notebook

Security Architecture & Trust Boundaries



Gemini Notebook

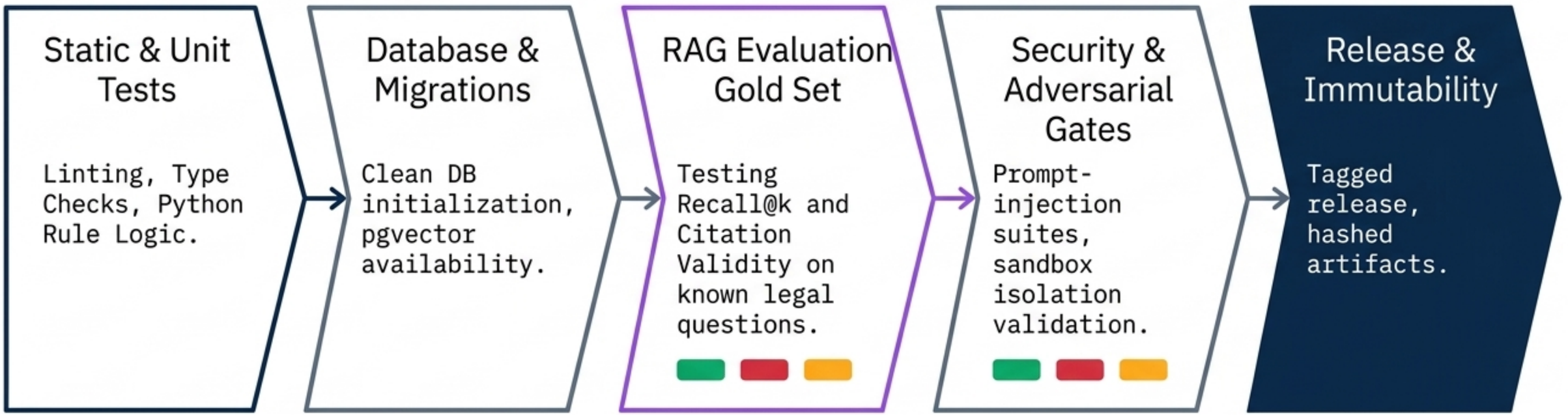
The Outcome Model & Temporal Applicability



Design Rule:
A missing piece of evidence is evaluated as **INSUFFICIENT_EVIDENCE**, not silently inferred as a **PASS** by the LLM. **"Not Yet Effective"** does not mean **"Not Applicable"**.

Gemini Notebook

Continuous Verification (CI/CD)



Key Insight: Continuous Verification: The pipeline blocks release if retrieval precision drops or if adversarial tests bypass intended controls. The LLM is tested like a microservice.

Gemini Notebook

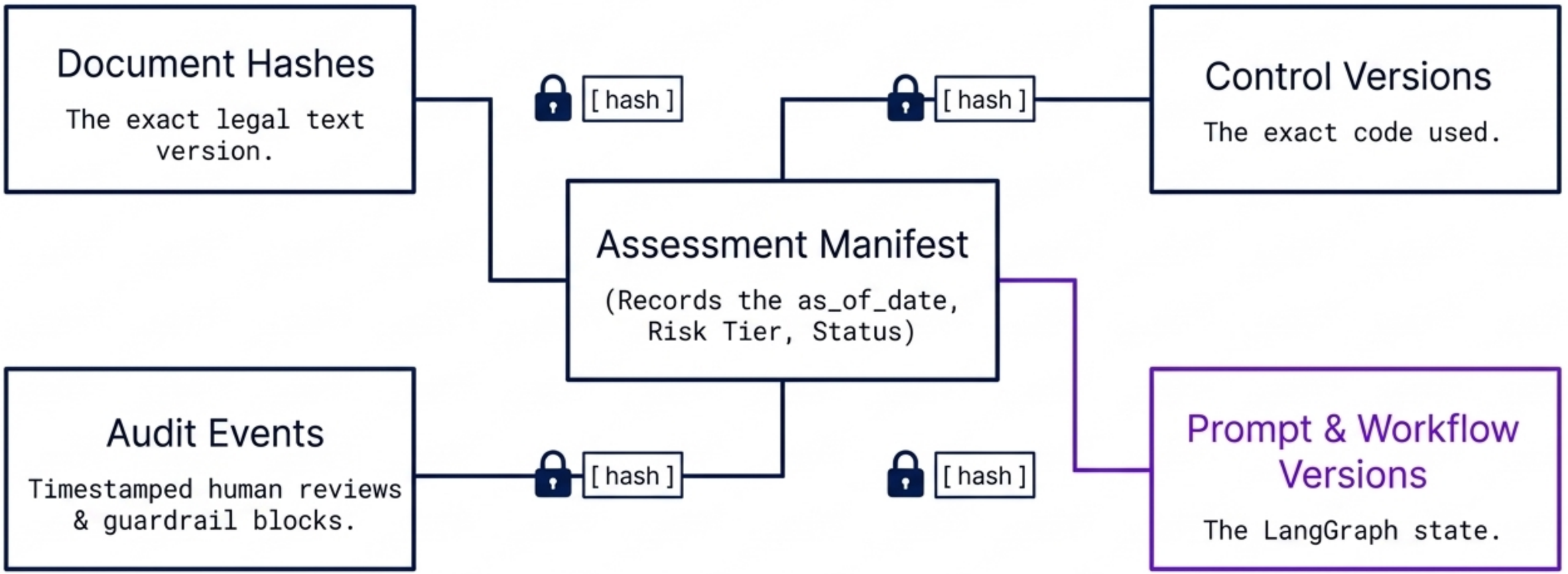
Deployment Profiles

Dimensions (Rows)	Local (Dev)	CI (Test)	Demo (Public)
Backend	API over HTTP	API over HTTP	In-process client
Persistence	Durable PostgreSQL	Ephemeral PostgreSQL	Bounded Ephemeral Store
Retrieval	pgvector	pgvector (test corpus)	File-based Index
Inference	Local Open-Weights Model	Recorded Fixtures	Replay / Optional Hosted
Target Application	Sandboxed Runner	Isolated Runner	Allowlisted HTTP only (No Arbitrary Code)

The codebase adapts to the infrastructure via configuration, requiring zero code changes between profiles.

Gemini Notebook

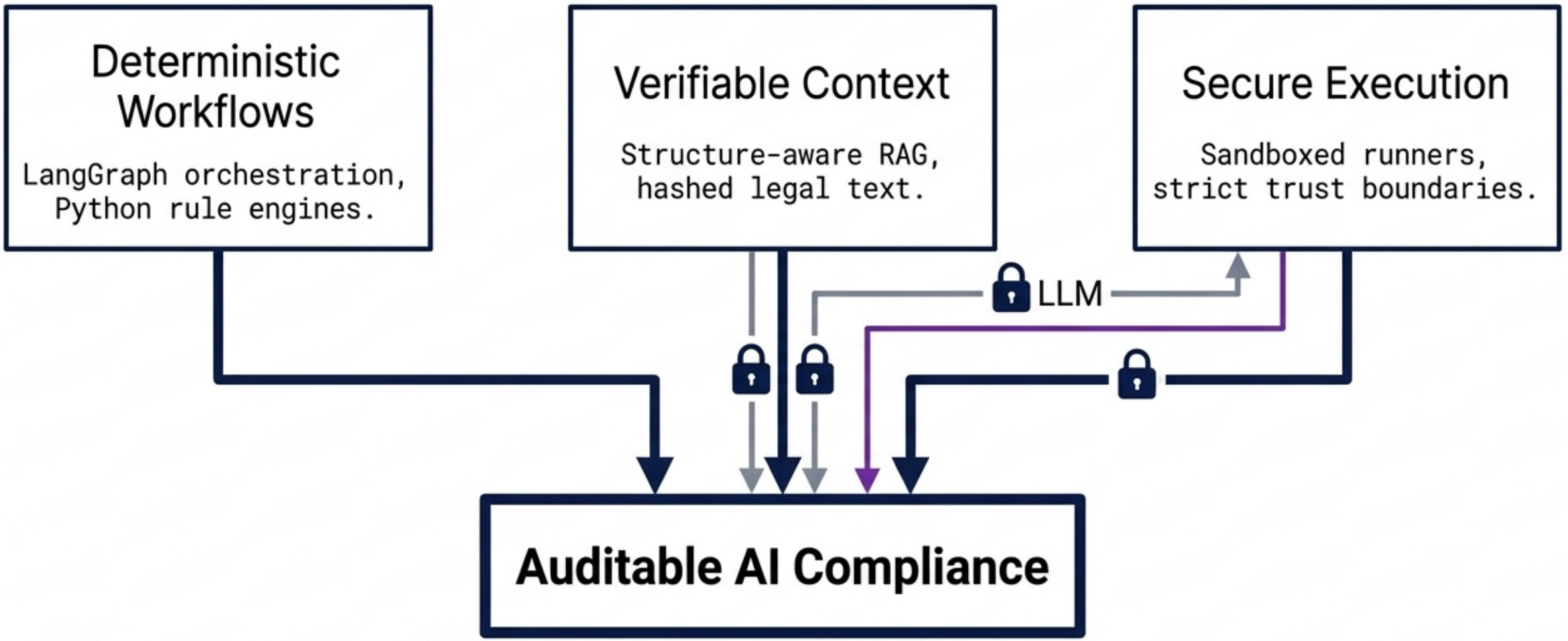
Audit & Persistence Layer



Configuration Reproducibility: Every manifest records the exact control catalog, prompt version, and embedding model used, ensuring historical assessments can be **perfectly reconstructed.**

Gemini Notebook

Architectural Summary



Enterprise AI is not about maximizing model autonomy. It is about wrapping non-deterministic capabilities in rigorous, verifiable software engineering.

Gemini Notebook